

Security Risk Assessment Report

Enterprise-style risk identification, analysis, treatment, and residual-risk review

Scenario. This work sample assesses a representative mid-sized online business with customer data, employee endpoints, cloud-hosted applications, remote access, third-party SaaS services, and payment workflows. Ratings are illustrative and demonstrate risk-analysis methodology rather than a formal audit opinion.

Executive Summary

- The highest risks are weak privileged-access governance, incomplete centralized logging, internet-facing vulnerability exposure, inconsistent recovery testing, and phishing-driven credential compromise.
- Risk treatment prioritizes MFA, least privilege, centralized security logging, risk-based vulnerability SLAs, tested backups, and security-awareness controls.
- Residual risk remains where business dependencies or implementation constraints prevent immediate elimination; those risks require documented ownership, review dates, and compensating controls.

Risk Scoring Method

Likelihood	Definition	Impact	Definition
1 - Rare	Unlikely under normal conditions	1 - Minimal	Negligible operational or data impact
2 - Unlikely	Possible but not expected	2 - Minor	Limited disruption; low sensitivity
3 - Possible	Credible and plausible	3 - Moderate	Material team/service impact
4 - Likely	Expected under current exposure	4 - Major	Significant outage, loss, or disclosure
5 - Almost certain	Highly probable / active exposure	5 - Severe	Enterprise, legal, financial, or major customer impact

Risk Register Summary

ID	Risk scenario	L	I	Inherent	Key controls / treatment	Residual	Owner
R-01	Compromised privileged account enables unauthorized administrative activity.	4	5	20 Critical	Phishing-resistant MFA, PAM, quarterly access reviews, admin log monitoring.	8 Medium	IAM / Security
R-02	Critical internet-facing vulnerability is exploited before remediation.	4	5	20 Critical	Asset inventory, weekly scanning, 7-day critical SLA, emergency patch process, WAF.	10 High	Infrastructure
R-03	Incomplete logging delays detection and investigation of malicious activity.	4	4	16 High	Central SIEM, required source list, 90-day searchable retention, alert ownership.	8 Medium	SOC / IT
R-04	Ransomware disrupts systems and corrupts accessible backups.	3	5	15 High	EDR, segmentation, immutable/offline backups, restore testing, least privilege.	6 Medium	IT / BCP
R-05	Phishing leads to user credential theft and unauthorized access.	4	4	16 High	MFA, email filtering, awareness training, risky-sign-in detection, resets.	8 Medium	Security / IAM
R-06	Third-party SaaS breach exposes business or customer information.	3	4	12 High	Vendor risk review, contract controls, SSO/MFA, least privilege, data minimization.	6 Medium	Procurement / GRC
R-07	Misconfigured cloud storage exposes sensitive data.	3	5	15 High	Private-by-default templates, CSPM checks, encryption, change review, alerts.	5 Medium	Cloud / Security
R-08	Recovery process fails to meet business RTO/RPO during disruption.	3	4	12 High	Documented RTO/RPO, quarterly restore tests, backup monitoring, recovery runbooks.	6 Medium	IT / Business

Treatment Priorities

- **0-30 days:** Enforce MFA on privileged and remote access; close critical internet-facing vulnerabilities; confirm backup integrity; onboard missing identity and administrative logs.
- **31-60 days:** Complete privileged-access review, formalize vulnerability SLAs, test incident escalation, and verify third-party access restrictions.
- **61-90 days:** Complete restore exercise, review residual risks, measure overdue remediation, and provide leadership reporting on risk reduction.

Governance & Validation

- Risk owners accept, mitigate, transfer, or avoid risk; security/GRC documents the rationale and review cycle.
- Critical and high risks are reviewed monthly until reduced; medium risks are reviewed quarterly; accepted risks require an expiration or review date.
- Risk closure requires evidence that the control is implemented and operating, not only a completed ticket.
- Framework alignment: NIST CSF 2.0 Govern/Identify/Protect/Detect/Respond/Recover; NIST SP 800-53 control families; ISO/IEC 27001 risk-treatment principles.